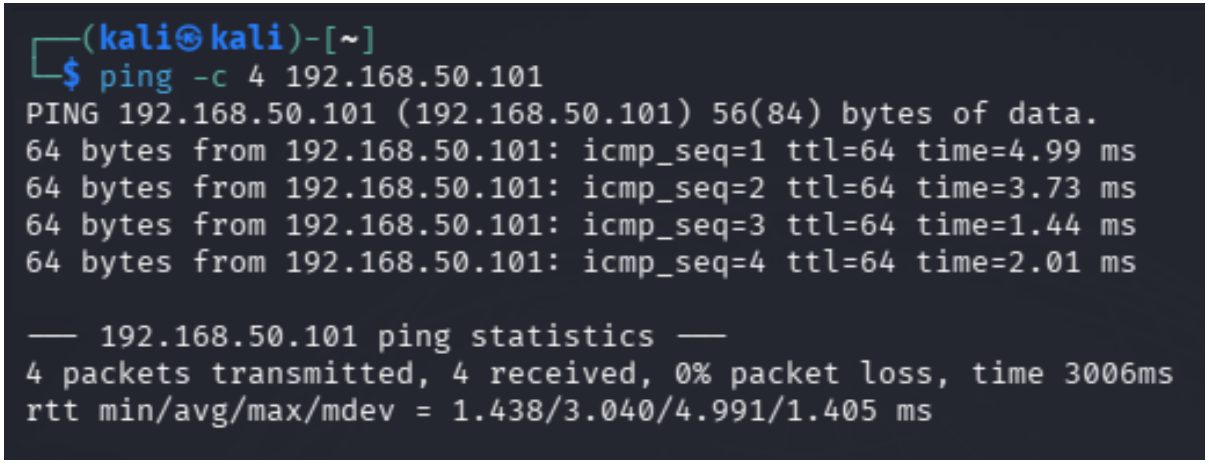
Studentessa	Corso	Attività svolta
Martina Foresta	Cybersecurity	XSS Reflected e SQL Injection in DVWA

Verifica delle vulnerabilità XSS Reflected e SQL Injection in DVWA

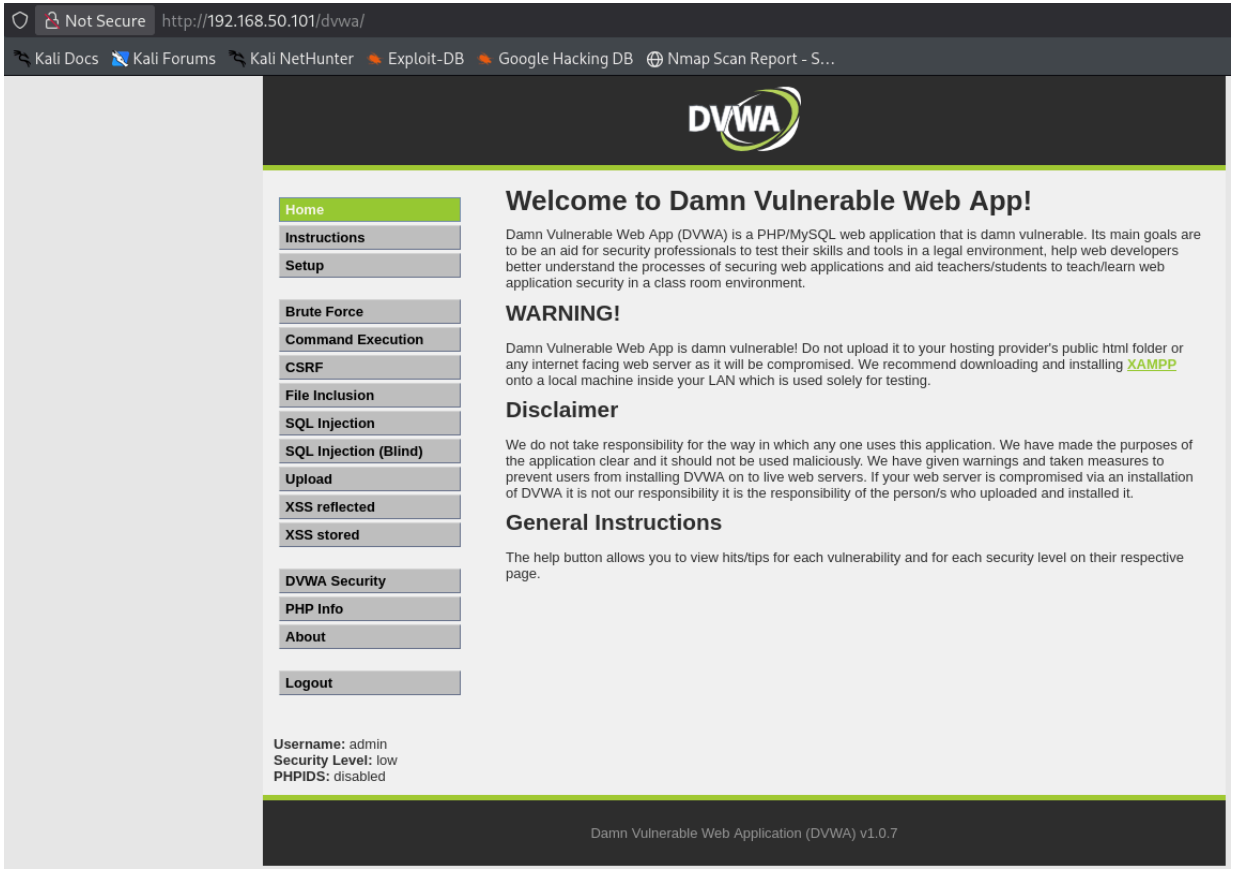
1 Verifica della connettività

Il comando ping ha ricevuto quattro risposte dalla macchina DVWA, senza perdita di pacchetti. La comunicazione tra Kali e il laboratorio è quindi attiva.



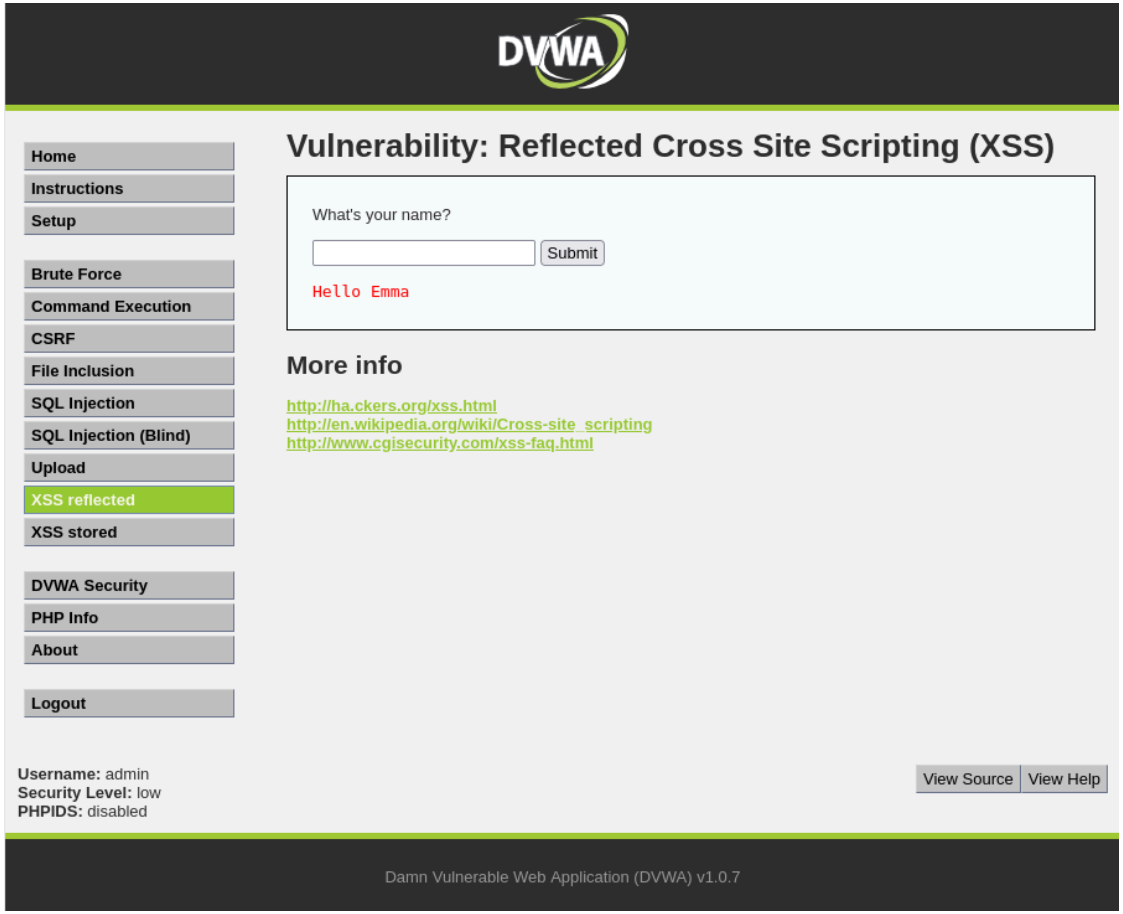
2 Configurazione di DVWA

Dopo l'accesso a DVWA, il livello di sicurezza è stato impostato su Low, come richiesto dalla traccia.



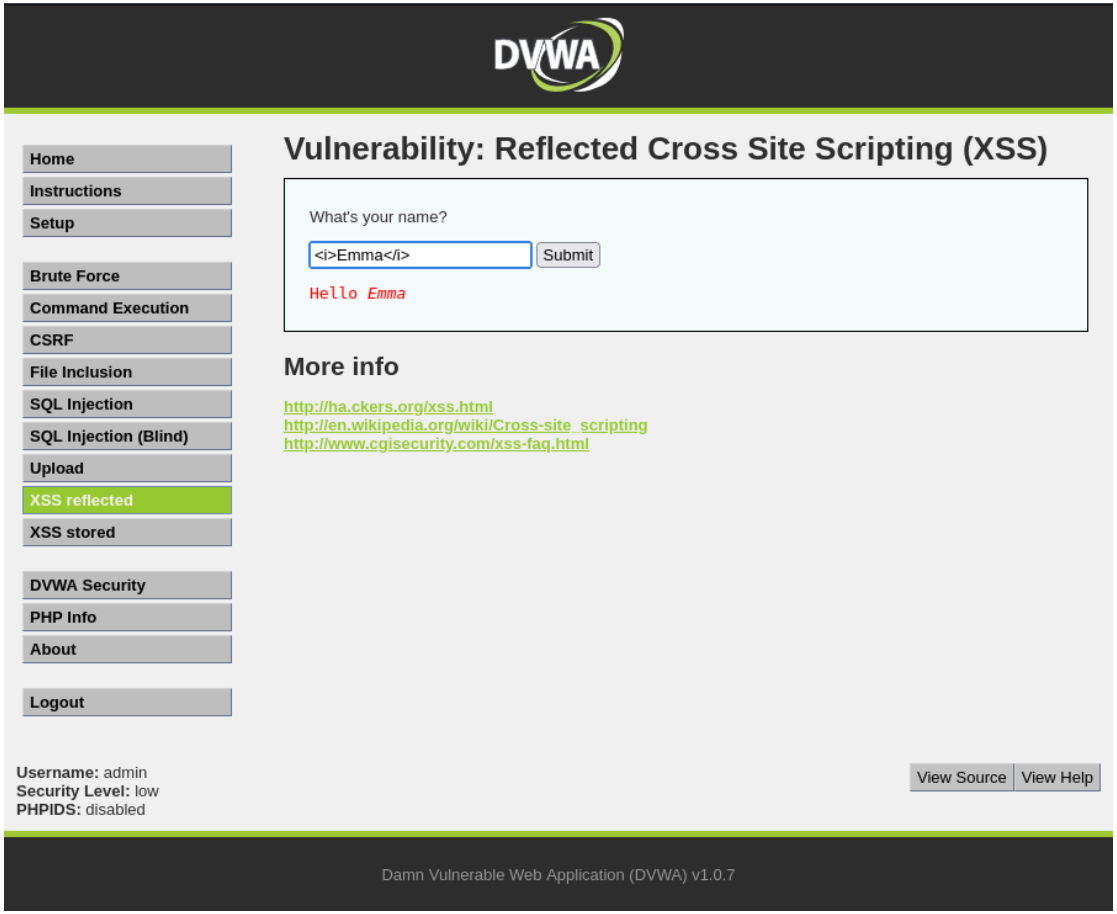
3 XSS Reflected: riflessione dell'input

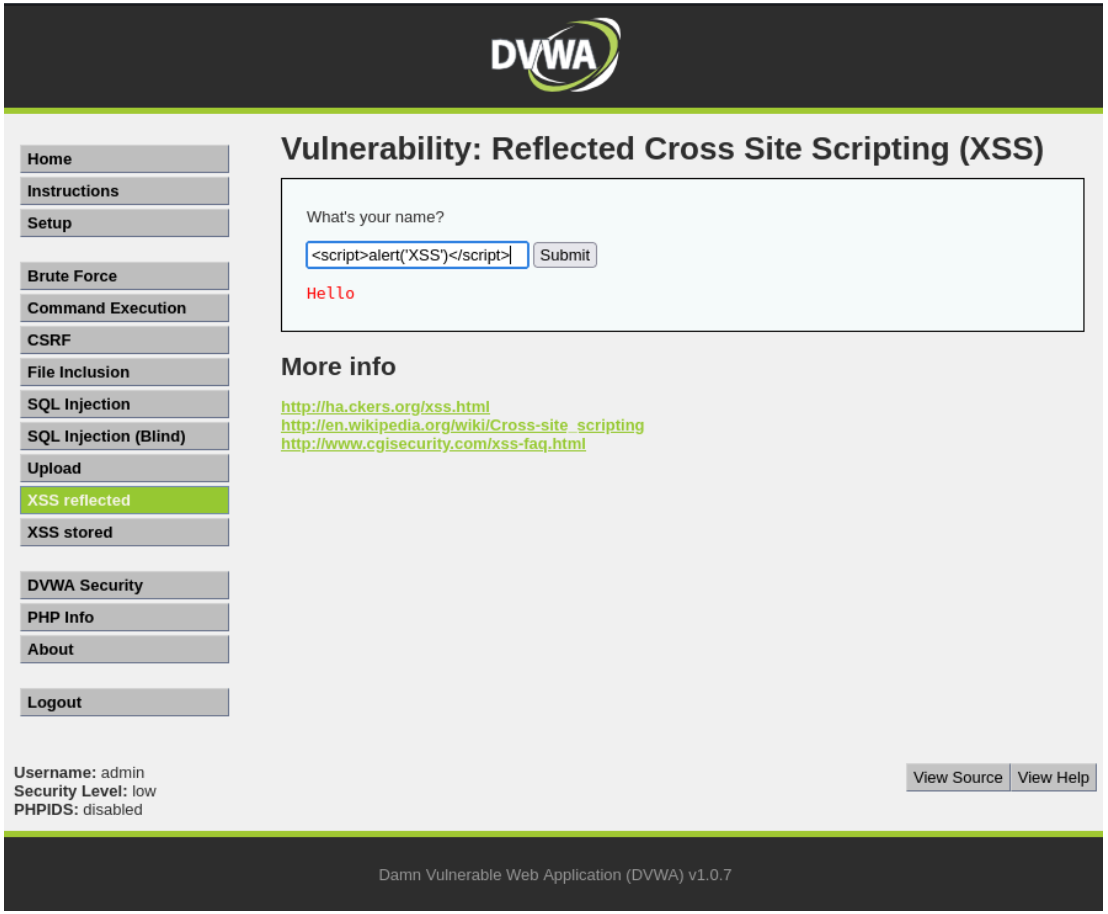
Nel campo del nome è stato inserito il valore Emma. La pagina lo ha restituito nell'output come Hello Emma, mostrando che l'input dell'utente viene riflesso nella risposta.

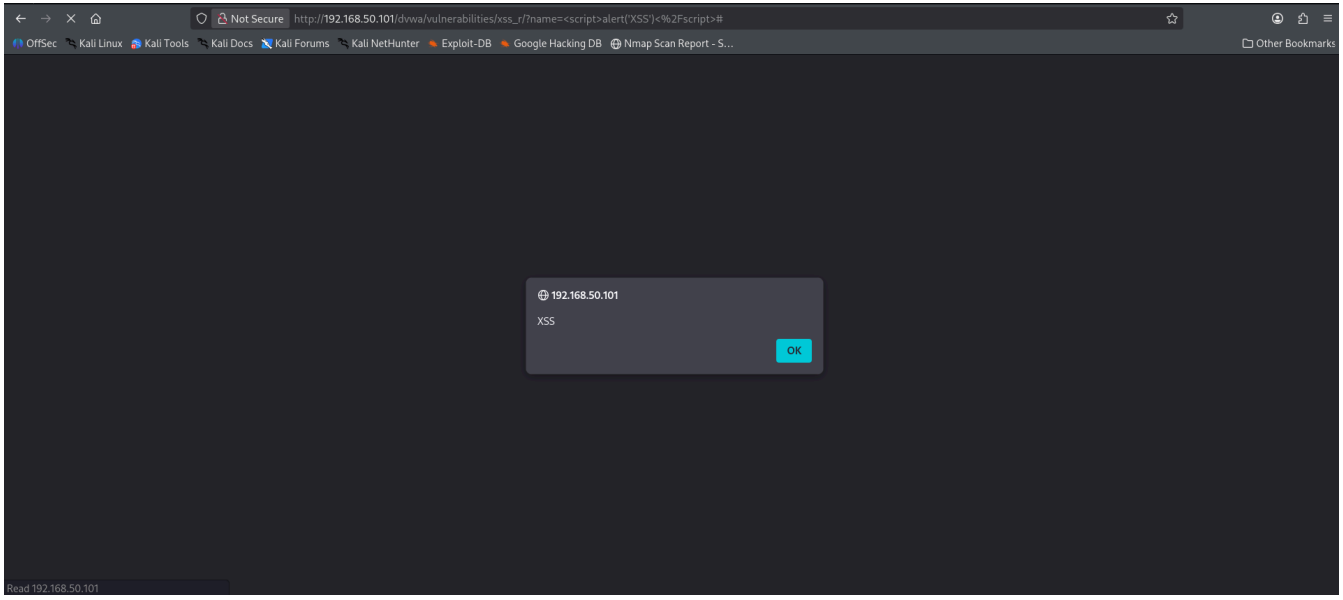


4 XSS Reflected: interpretazione HTML e JavaScript

Inserendo il tag HTML Emma, il nome è comparso in corsivo. In seguito l'avviso XSS ha confermato che il browser ha eseguito il codice JavaScript inserito nel campo.

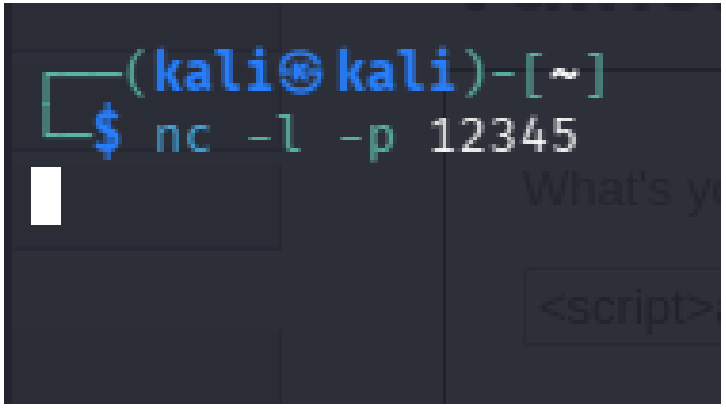

DVWA
Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
About
Logout
Vulnerability: Reflected Cross Site Scripting (XSS)
What's your name?
Emma
Submit
Hello Emma
More info
http://ha.ckers.org/xss.html
http://en.wikipedia.org/wiki/Cross-site_scripting
http://www.cgisecurity.com/xss-faq.html
Username: admin
Security Level: low
PHPIDS: disabled
View Source
View Help
Damn Vulnerable Web Application (DVWA) v1.0.7

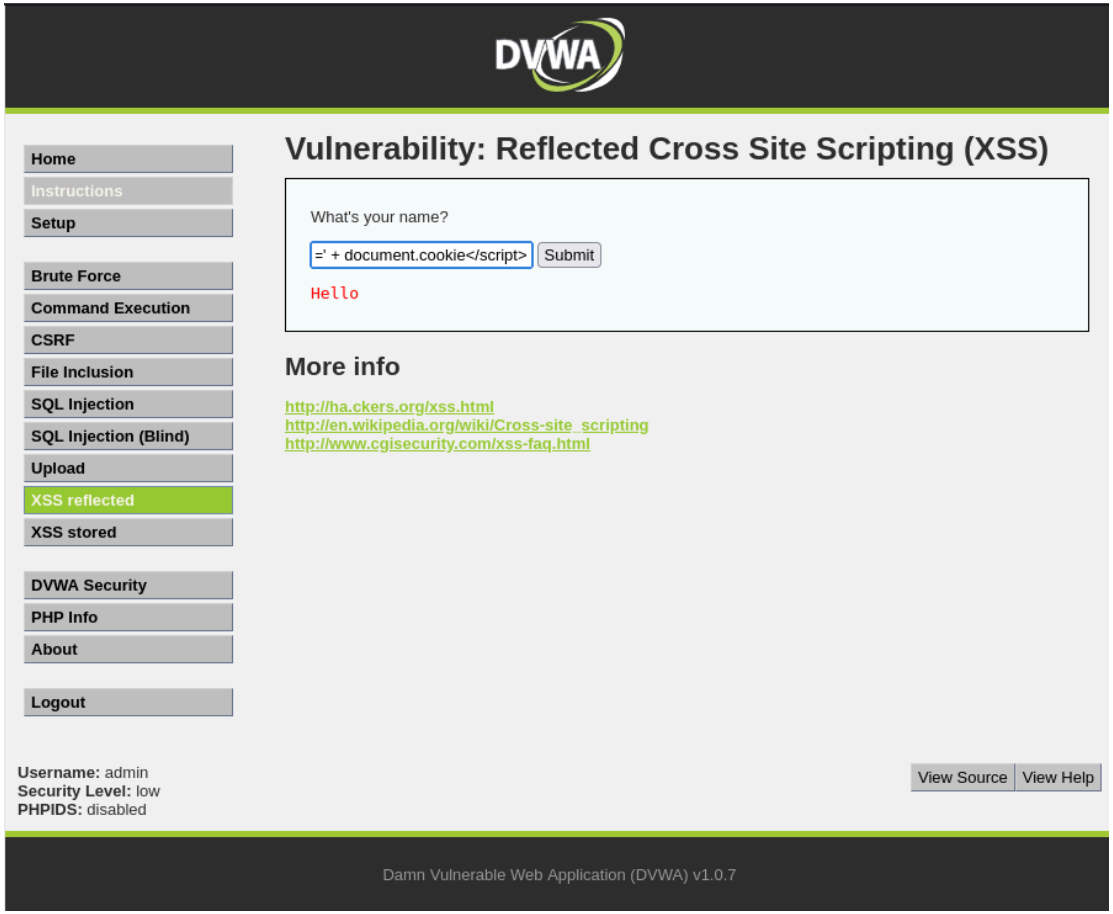

DVWA
Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
About
Logout
Vulnerability: Reflected Cross Site Scripting (XSS)
What's your name?
<script>alert('XSS')</script>
Submit
Hello
More info
http://ha.ckers.org/xss.html
http://en.wikipedia.org/wiki/Cross-site_scripting
http://www.cgisecurity.com/xss-faq.html
Username: admin
Security Level: low
PHPIDS: disabled
View Source
View Help
Damn Vulnerable Web Application (DVWA) v1.0.7

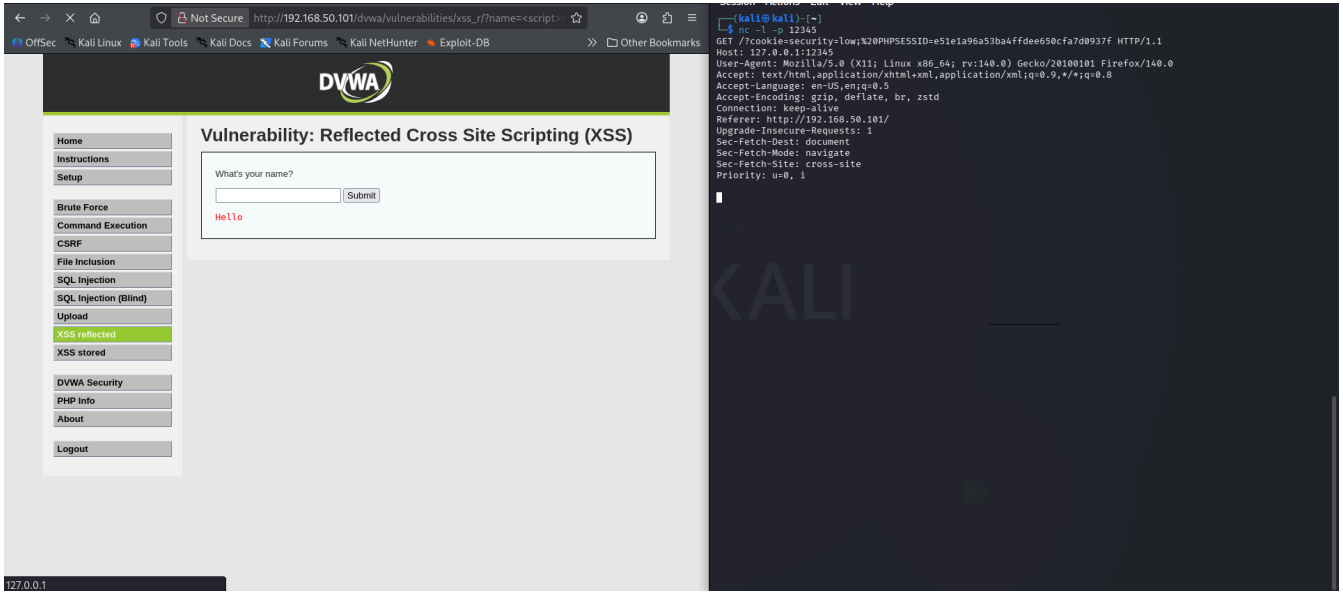


5 Cookie e listener locale

Su Kali è stato avviato un listener locale con Netcat sulla porta 12345. Lo script XSS ha indirizzato il browser al listener locale includendo il cookie della sessione nella richiesta. Il terminale ha ricevuto la richiesta HTTP.




DVWA
Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
About
Logout
Vulnerability: Reflected Cross Site Scripting (XSS)
What's your name?
=' + document.cookie</script>
Submit
Hello
More info
http://ha.ckers.org/xss.html
http://en.wikipedia.org/wiki/Cross-site_scripting
http://www.cgisecurity.com/xss-faq.html
Username: admin
Security Level: low
PHPIDS: disabled
View Source
View Help
Damn Vulnerable Web Application (DVWA) v1.0.7



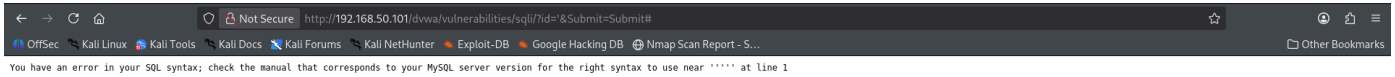
6 SQL Injection: comportamento normale

Nel campo User ID è stato inserito il valore 2. DVWA ha restituito il record associato, con nome Gordon e cognome Brown: il valore inserito viene quindi usato per interrogare il database.



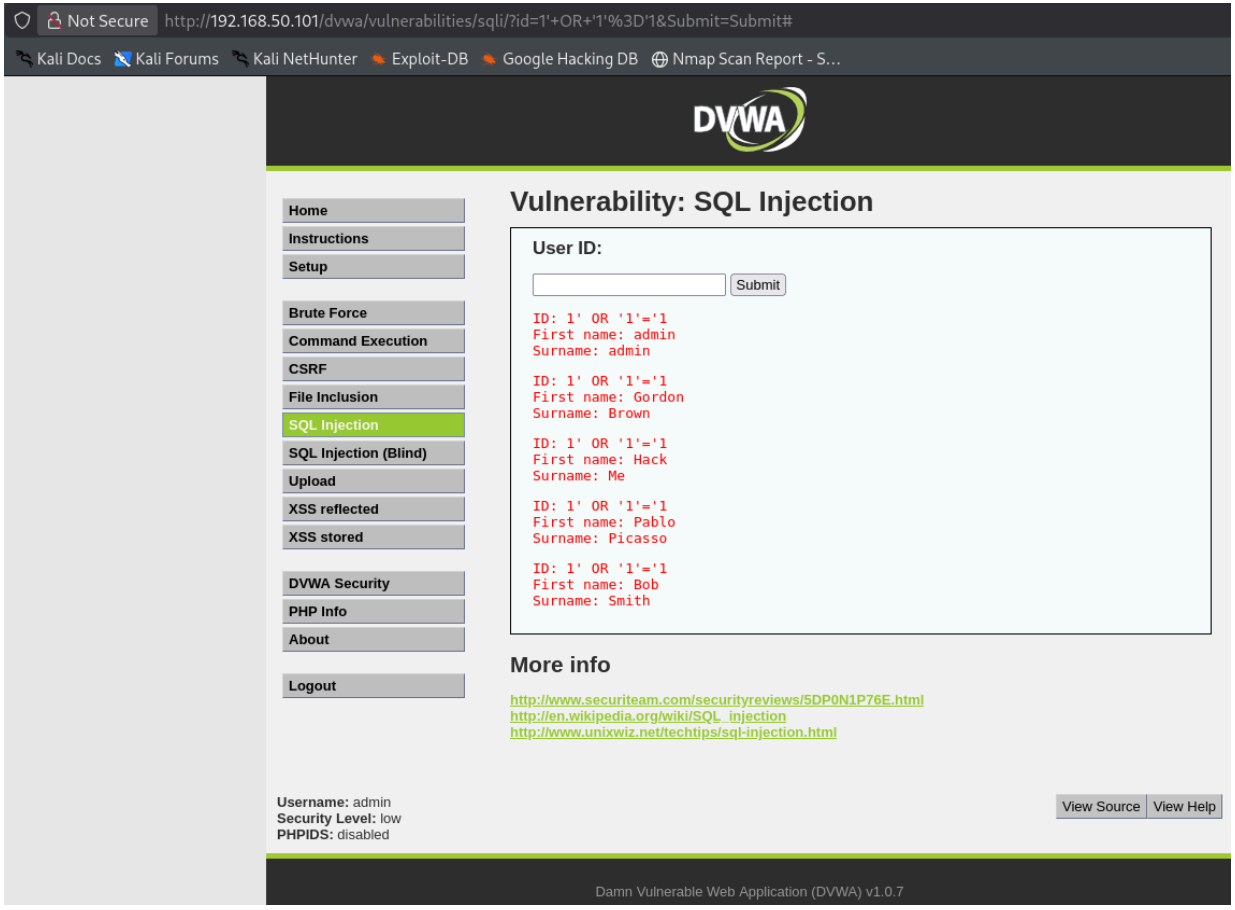
7 SQL Injection: controllo con apostrofo

Inserendo un apostrofo, l'applicazione ha mostrato un errore di sintassi MySQL. Questo indica che l'input raggiunge la query SQL senza una gestione adeguata dei caratteri speciali.



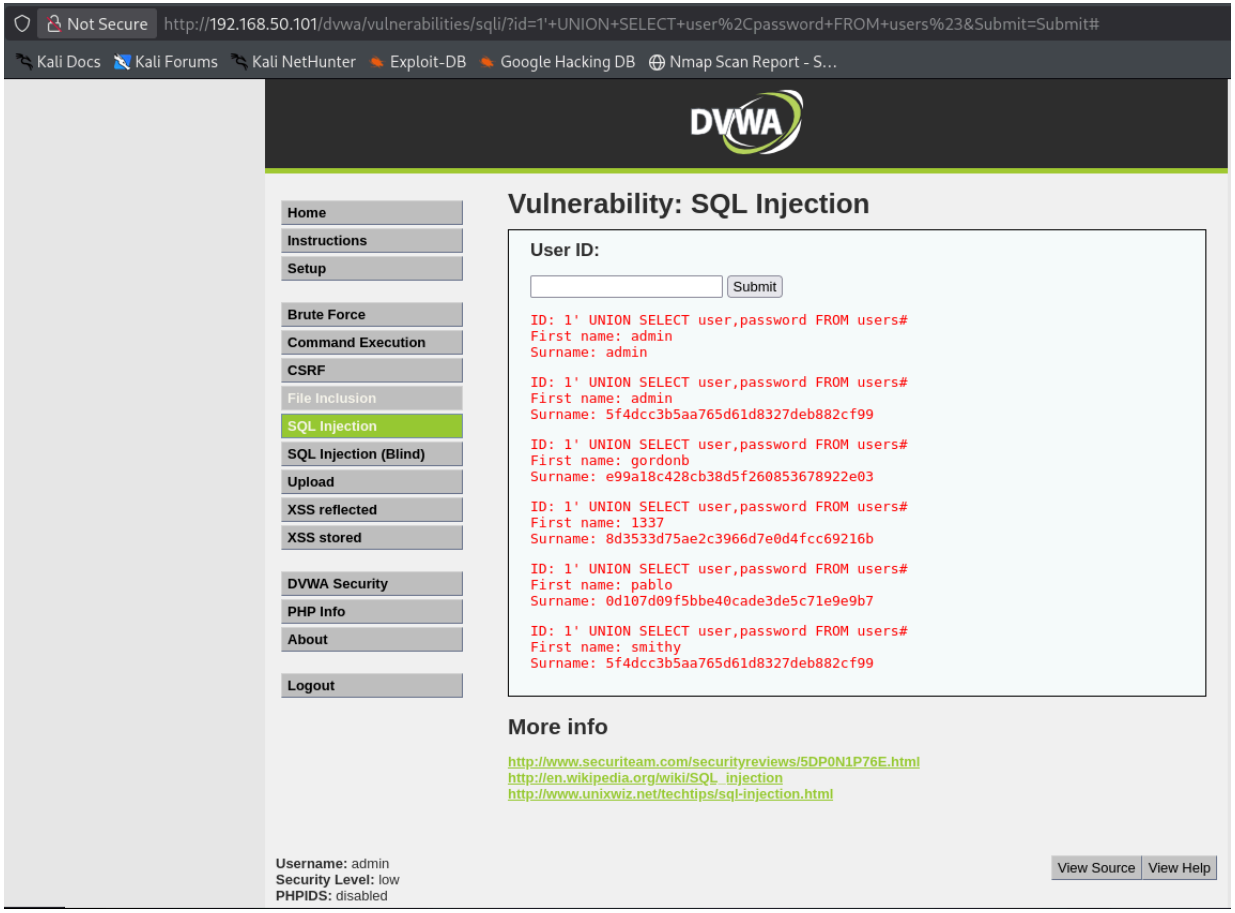
8 SQL Injection: condizione sempre vera

La condizione OR inserita nel campo User ID ha restituito più record della tabella, invece del singolo record atteso. Il risultato conferma che la condizione della query può essere alterata dall'input.



9 SQL Injection con UNION

La query UNION ha visualizzato i nomi utente e i valori memorizzati per le password. I valori delle password mostrati sono hash, non password in chiaro.



Conclusione

Nel livello Low di DVWA, l'input non viene gestito in modo sicuro: nell'XSS Reflected può essere interpretato dal browser, mentre nella SQL Injection può modificare la query del database.